Il est recommandé d'utiliser des serveurs privés virtuels (VPS) avec différentes adresses IP en effet certains peuvent se retrouver blacklister par l'IPS/IDS cible ou pire l'entreprise relate l'attaque avec logs et type de scan à l'appui et signale l'IP comme malveillante à notre FAI on peux ainsi se retrouver sans internet du jour au lendemain.

Le scan furtif ou (-D) permet de générer des adresses IP aléatoires pour masquer l'origine du paquet envoyé Notre véritable IP est ensuite placé au hasard parmi les IPs générées Ex si j'en veux 5. -D RND:5

Pour tester avec une adresse IP précise de notre choix : -S ipchoisi -e interface-réseaux. attention les données renvoyées à notre IP spécifié si c'est pas la notre on ne recevra absolument rien.

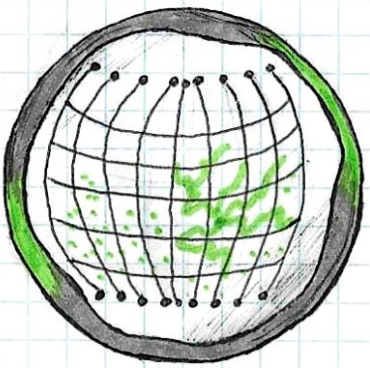
- Les DNS Internes :

Si nous avons mis pied dans un réseau d'entreprise (DMZ: Zone demilitarisée) si nous utilisons les serveurs internet de bases d'internet (Ex google 8.8.8.8 ceux utilisés par default par nmap on pourras pas joindre le serveur secret de l'entreprise (Ex comptabilité interne). Il faut donc forcer nmap a interroger directement le serveur DNS Privé de l'entreprise avec : --dns-server ipdudns

Quelques techniques de Furtivité :

1- Quand un ordinateur de l'entreprise veux aller sur internet ou faire une requête DNS, le pare-feu doit le laisser sortir, puis laisser la réponse entrer. Un pare-feu mal configuré accepte tout paquets ou certains venant du port 53. on peux demander a nmap de utiliser le port 53 pour nos paquets d'attaques avec : --source-port 53 ou -g 53

2- On peux fragmenter nos paquets avec -f ou -ff pour encore plus petit. Nmap découpe ainsi l'en-tête TCP en plusieurs morceaux Le pare-feu reçoit les fragments incomplets et à beaucoup de mal à reconstituer la signature de l'attaque en temps réel le scan passe souvent sous les radars pour pousser plus loin on peux spécifier la taille des morceaux (en octet donc forcément multiple de 8) avec --mtu 16 ou --mtu 8



Recherche d'Informations

Catégorie : ⚔ Offensif
Difficulté : Medium, Tier II
Durée Estimé : 2 Jours

Les Principes de l'énumération :

En cybersécurité l'énumération désigne la collecte d'informations à l'aide de méthodes actives et passives. L'OSINT est une procédure indépendante. On réalise une énumération "en bouclant" sur les éléments nouveaux que nous découvrons. Le but étant pas d'attaquer la cible mais de savoir frapper ou et à coup sur.

[+] - Il y a plus que ce que l'on voit, il faut considérer tout les points de vue.
[+] - Faire la distinctions entre ce que l'on voit et ne voit pas
[+] - Il y a toujours le moyen d'obtenir plus d'informations, comprenez la cible !!